HALLAZGO TCK-25B8E4 Nuevo

Software Seguro v1.0.0

Plantilla: Auditoría de Seguridad
Ref ID: TCK-25B8E4

TÍTULO DE LA VULNERABILIDAD

IDOR en la API de turnos: acceso y eli minación de turnos de otros usuarios

NIVEL DE CRITICIDAD

Alta

RESUMEN EJECUTIVO

El riesgo en lenguaje de negocio: leer agendas ajenas + cancelar turnos de víctimas

ENDPOINT O URL AFECTADA

GET /api/1/appointments/{id}
DELETE /api/appointments/{id}

CASO DE USO ASOCIADO

N/A (No Aplica)

VERIFICACIÓN OWASP ASVS V4.0.3

- ✓ **V4.2.1** - Verifique que los datos confiden ciales y las API están protegidos contra at aques de referencia insegura directa de o bjetos (IDOR)... como la visualización de lo s registros de todos o la eliminación de to dos los registros.
- ✓ **V4.1.1** - Verifique que la aplicación aplica las reglas de control de acceso en una cap a de servicio de confianza, especialmente si el control de acceso del lado cliente est á presente y podría ser bypaseado.
- ✓ **V1.4.1** - Verifique que los puntos de cum plimiento de confianza, tales como puerta s de enlace de control de acceso, servidor es y funciones serverless, exijan controles de acceso. Nunca aplique controles de ac ceso en el cliente.

PUNTUACIÓN CVSS V3.1

6.3 (CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:U/ C:L/I:L/A:L)

DESCRIPCIÓN DETALLADA DEL HALLAZGO

XHR → DELETE observado → enumeración manual hasta 30 → Burp Intruder 0-150 → ID 10 1 → borrado masivo

PRUEBA DE CONCEPTO (POC) Y PASOS DE REPRODUCCIÓN

RECOMENDACIÓN DE REMEDIACIÓN & MITIGACIÓN

Los 8 pasos numerados, incluyendo la nota de que la enumeración manual fue insuficiente (refuerza el hallazgo)

6 medidas: autorización a nivel de objeto (crítica), UUIDs, confirmación en DELETE, rate limiting, errores indistinguibles y tests de regresión